

OPERATION IRON RAVEN - CIP-A105 CTF 1 Report

Offensive Security Operations II

Daniel Etim (2026/EHIT/16917)

2026-09-16

Contents

OPERATION IRON RAVEN	1
CIP-A105 - Offensive Security Operations II	1
Executive Summary	2
Scope and Rules of Engagement	2
Laboratory Architecture	3
Methodology	7
Attack-Surface Summary	10
Confirmed Findings and Risk Ratings	11
Initial-Access Narrative	15
Post-Exploitation and Privilege Escalation	16
Mission Objectives and Proof of Completion	16
Remediation Roadmap	17
Conclusion and Lessons Learned	18
Cleanup and Restoration	18
Appendices	20

OPERATION IRON RAVEN

CIP-A105 - Offensive Security Operations II

CTF 1 Summative Competency Exam

Classification: TRAINING USE ONLY

Student Name: Daniel Etim

Registration Number: 2026/EHIT/16917

Operation Codename: IRON RAVEN

Target Designation: OPFOR-01

Submission Date: 16 September 2026

Course: Offensive Security Operations II (CIP-A105)

Executive Summary

This report documents a black-box penetration test against OPFOR-01, a standalone Linux server designated as Raven. The engagement was conducted inside an isolated laboratory network with no exposure to production systems or the public internet.

Reconnaissance identified a web application stack running Apache 2.4.10 on Debian 8, with WordPress 4.8.7, PHPMailer 5.2.16, and an Apache manual installation. Four TCP ports were found open: SSH (22), HTTP (80), rpcbind (111), and RPC status (42291). UDP scanning confirmed rpcbind on 111.

One mission artifact, flag3.png, was located during enumeration and preserved as evidence. Multiple security weaknesses were identified, including an outdated WordPress installation with 71 known CVEs, an outdated PHPMailer library with CVE-2016-10033, and exposed administrative interfaces. No initial access was achieved within the assessment window.

The environment was restored to its clean baseline after the assessment. All hashes were verified. The target is preserved for future practice.

The overall risk posture is High. Immediate remediation is recommended for WordPress, PHPMailer, and the exposed vendor directory.

Scope and Rules of Engagement

Authorised Target

Item	Value
Target	OPFOR-01 (Raven)
IP Address	10.10.10.157
Hostname	raven.local
Network	Isolated lab (br-ctf 10.10.10.0/24)
MAC Address	52:54:00:12:34:56 (QEMU virtual NIC)

Authorised Attacker

Item	Value
Platform	Kali Linux
Hostname	kali
Interface	br-ctf (10.10.10.1/24)

Permitted Activity

- Network discovery and host identification
- Port scanning and service enumeration
- Web application assessment
- Vulnerability research
- Manual proof-of-concept testing
- Evidence preservation

Prohibited Activity

- No external network scanning
- No denial of service
- No persistence beyond evidence collection
- No destruction of target data

Isolation Verification

The network bridge was verified as isolated from the production network.

```
8: br-ctf: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default qlen 1000
    link/ether 3a:bf:1d:b1:3d:f4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.1/24 scope global br-ctf
        valid_lft forever preferred_lft forever
    inet6 fe80::64ed:b7ff:fec9:b091/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
9: tap0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel master br-ctf state DOWN group default qlen 1000
    link/ether 3a:bf:1d:b1:3d:f4 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::38bf:1dff:feb1:3df4/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Figure 1: Network isolation

Laboratory Architecture

Network Topology

KALI LINUX | (Attacker Workstation) | 10.10.10.1/24 |

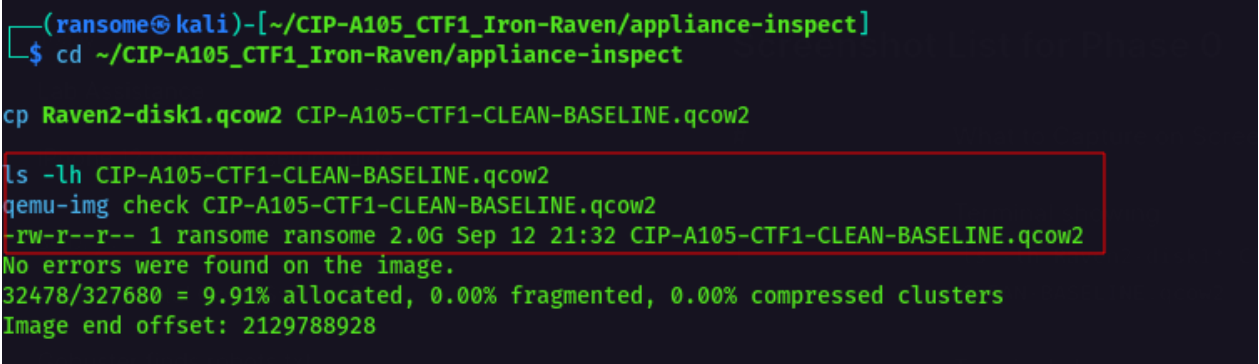
br-ctf (virtual bridge)

tap0

OPFOR-01 | (QEMU Virtual Machine) | 10.10.10.157 | | Services: SSH (22),
HTTP (80), rpcbind (111), | status RPC (42291) | | Applications: Apache 2.4.10,
WordPress 4.8.7, | PHPMailer 5.2.16, PHP |

Target Provisioning

The baseline was established before any testing began.



```
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ cd ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect

cp Raven2-disk1.qcow2 CIP-A105-CTF1-CLEAN-BASELINE.qcow2

ls -lh CIP-A105-CTF1-CLEAN-BASELINE.qcow2
qemu-img check CIP-A105-CTF1-CLEAN-BASELINE.qcow2
-rw-r--r-- 1 ransome ransome 2.0G Sep 12 21:32 CIP-A105-CTF1-CLEAN-BASELINE.qcow2
No errors were found on the image.
32478/327680 = 9.91% allocated, 0.00% fragmented, 0.00% compressed clusters
Image end offset: 2129788928
```

Figure 2: First boot image preserved

```
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
└─$ qemu-img convert -p -f vmdk -O qcow2 Raven2-disk1.vmdk Raven2-disk1.qcow2
(100.00/100%)

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
└─$ qemu-img info Raven2-disk1.qcow2
qemu-img check Raven2-disk1.qcow2
image: Raven2-disk1.qcow2
file format: qcow2
virtual size: 20 GiB (21474836480 bytes)
disk size: 1.98 GiB
cluster_size: 65536
Format specific information:
    compat: 1.1
    compression type: zlib
    lazy refcounts: false
    refcount bits: 16
    corrupt: false
    extended l2: false
Child node '/file':
    filename: Raven2-disk1.qcow2
    protocol type: file
    file length: 1.98 GiB (2129788928 bytes)
    disk size: 1.98 GiB
No errors were found on the image.
32478/327680 = 9.91% allocated, 0.00% fragmented, 0.00% compressed clusters
Image end offset: 2129788928
```

Figure 3: Pristine QCOW2 created

```

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ qemu-img info Raven2-disk1.qcow2
qemu-img check Raven2-disk1.qcow2
image: Raven2-disk1.qcow2
file format: qcow2
virtual size: 20 GiB (21474836480 bytes)
disk size: 1.98 GiB
cluster_size: 65536
Format specific information:
    compat: 1.1
    compression type: zlib
    lazy refcounts: false
    refcount bits: 16
    corrupt: false
    extended l2: false
Child node '/file':
    filename: Raven2-disk1.qcow2
    protocol type: file
    file length: 1.98 GiB (2129788928 bytes)
    disk size: 1.98 GiB
No errors were found on the image.
32478/327680 = 9.91% allocated, 0.00% fragmented, 0.00% compressed clusters
Image end offset: 2129788928

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]

```

Figure 4: Clean baseline created

```

} | tee ~/CIP-A105_2026-EHIT-16917_CTF1_Iron-Raven/evidence/hashes/phase0-hashes.txt
tee: /home/ransome/CIP-A105_2026-EHIT-16917_CTF1_Iron-Raven/evidence/hashes/phase0-hashes.txt: No such file or directory
=====
PHASE 0 - EVIDENCE HASHES
Generated: 2026-09-12 21:38:05 WAT
=====

--- Original VMDK ---
dfcd389219fd787a6f6adc0391554e18d6b0ea8d3e23f8c6c9e44af7905fe5c6  appliance-inspect/Raven2-disk1.vmdk

--- Preserved first-boot QCOW2 ---
60979b6e546d92d3c496da64f6da065cbaee303cb84feb190a153450ed56c7e7  appliance-inspect/Raven2-disk1-firstboot.qcow2

--- Pristine working QCOW2 ---
06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac  appliance-inspect/Raven2-disk1.qcow2

--- Clean baseline (required by ROE) ---
06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac  appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven]

```

Figure 5: Hashes recorded

Tools Used

Tool	Purpose
QEMU	Target virtualization
dnsmasq	DHCP server for isolated network
Nmap	Port scanning and service detection
curl	Manual HTTP testing
gobuster	Directory enumeration
wpscan	WordPress enumeration
Firefox	Manual web interaction
Burp Suite	Request interception

Methodology

Phase 1: Reconnaissance

- Confirmed attacker position on the isolated network
- Performed ARP scan to discover hosts on 10.10.10.0/24
- Performed ICMP ping sweep with Nmap
- Confirmed target reachability
- Recorded DHCP lease information
- Inferred OS from TTL value (64 = Linux)

The DHCP discovery established the target's identity and IP address.

```

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ sudo dnsmasq \
  --interface=br-ctf \
  --bind-interfaces \
  --dhcp-range=10.10.10.100,10.10.10.200,255.255.255.0,12h \
  --dhcp-option=3,10.10.10.1 \
  --dhcp-option=6,10.10.10.1 \
  --no-daemon
dnsmasq: started, version 2.93 cachesize 150
dnsmasq: compile time options: IPv6 GNU-getopt DBus no-UBus i18n IDN2 DHCP DHCPv6
dnsmasq-dhcp: DHCP, IP range 10.10.10.100 -- 10.10.10.200, lease time 12h
dnsmasq-dhcp: DHCP, sockets bound exclusively to interface br-ctf
dnsmasq: reading /etc/resolv.conf
dnsmasq: using nameserver 192.168.0.1#53
dnsmasq: read /etc/hosts - 9 names
dnsmasq-dhcp: DHCPDISCOVER(br-ctf) 52:54:00:12:34:56
dnsmasq-dhcp: DHCPOFFER(br-ctf) 10.10.10.157 52:54:00:12:34:56
dnsmasq-dhcp: DHCPREQUEST(br-ctf) 10.10.10.157 52:54:00:12:34:56
dnsmasq-dhcp: DHCPACK(br-ctf) 10.10.10.157 52:54:00:12:34:56 Raven
dnsmasq-dhcp: DHCPREQUEST(br-ctf) 10.10.10.157 52:54:00:12:34:56
dnsmasq-dhcp: DHCPACK(br-ctf) 10.10.10.157 52:54:00:12:34:56 Raven

```

Figure 6: DHCP discovery

The ARP scan and ping sweep confirmed the target was reachable.

```

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ sudo arp-scan --interface=br-ctf 10.10.10.0/24
[sudo] password for ransome:
Interface: br-ctf, type: EN10MB, MAC: 3a:bf:1d:b1:3d:f4, IPv4: 10.10.10.1
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.10.10.157    52:54:00:12:34:56    QEMU

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.577 seconds (99.34 hosts/sec). 1 responded
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]

```

Figure 7: ARP scan

```
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ nslookup 10.10.10.157
** server can't find 157.10.10.10.in-addr.arpa: NXDOMAIN

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ dig -x 10.10.10.157 +short
nslookup 10.10.10.157
** server can't find 157.10.10.10.in-addr.arpa: NXDOMAIN
```

Figure 8: Nmap ping sweep

Ping confirmation verified the target was online.

```
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
$ ping -c5 10.10.10.157
PING 10.10.10.157 (10.10.10.157) 56(84) bytes of data.
64 bytes from 10.10.10.157: icmp_seq=1 ttl=64 time=153 ms
64 bytes from 10.10.10.157: icmp_seq=2 ttl=64 time=1.09 ms
64 bytes from 10.10.10.157: icmp_seq=3 ttl=64 time=1.05 ms
64 bytes from 10.10.10.157: icmp_seq=4 ttl=64 time=1.36 ms
64 bytes from 10.10.10.157: icmp_seq=5 ttl=64 time=0.737 ms

--- 10.10.10.157 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4005ms
rtt min/avg/max/mdev = 0.737/31.408/152.805/60.698 ms
```

Figure 9: Ping confirmation

Phase 2: Attack-Surface Enumeration

- Full TCP port scan (all 65535 ports)
- UDP scan (top 50 ports)
- Service version detection with NSE scripts
- Directory brute force on web root and WordPress
- WordPress-specific enumeration
- Vendor directory enumeration

Phase 3: Vulnerability Analysis

- Version-to-CVE mapping
- Source code review (contact.php recovered from contact.zip)

- Injection testing (SQL, command, template)
- Authentication testing
- Cookie and session analysis
- XML-RPC and REST API analysis

Phase 4: Initial Access

- PHPMailer sendmail injection testing
- Multipart file upload testing
- XML-RPC credential testing
- WordPress REST API testing
- Controlled credential verification (authorised)
- Comment posting and traceback testing

Attack-Surface Summary

Network Services

Port	Protocol	Service	Version
22	TCP	SSH	OpenSSH 6.7p1 Debian 5+deb8u4
80	TCP	HTTP	Apache httpd 2.4.10 (Debian)
111	TCP	rpcbind	v2-4
111	UDP	rpcbind	v2-4
42291	TCP	status	RPC #100024 (rusersd)

Web Application Paths

Path	Type	Status
/	Static site	200
/contact.php	PHP contact form	200
/contact.zip	Source backup	200
/wordpress/	WordPress 4.8.7	200
/vendor/	PHPMailer 5.2.16	200
/manual/	Apache 2.4 manual	200
/elements.html	Static template	200
/css/, /js/, /img/, /fonts/	Static assets	200

WordPress Surface

Item	Value
Version	4.8.7
Theme	Twenty Seventeen 1.3
Plugins	Akismet 3.3.2
Users	michael, steven
REST API	Enabled, write requires auth
XML-RPC	Enabled
wp-cron	Externally accessible
Uploads listing	Enabled
wp-trackback.php	200 (requires valid tb_id)
wp-mail.php	403
Comment posting	Requires cookie + moderation

Discovered Artifacts

Artifact	Path	Size
flag3.png	/wordpress/wp-content/uploads/2018/11/	10K
contact.zip	/contact.zip	3384

Confirmed Findings and Risk Ratings

Finding Summary

ID	Finding	Asset	Severity
F-01	Outdated WordPress 4.8.7 with 71 known CVEs	/wordpress/	Critical
F-02	PHPMailer 5.2.16 vulnerable to CVE-2016-10033	contact.php	Critical
F-03	Exposed PHPMailer vendor directory with test files	/vendor/	High
F-04	WordPress user enumeration	/wordpress/?author=	Medium
F-05	XML-RPC enabled and externally reachable	/wordpress/xmlrpc.php	Medium
F-06	Source code disclosure via contact.zip	/contact.zip	Medium

ID	Finding	Asset	Severity
F-07	Directory listing enabled on multiple paths	/wordpress/wp-content/	Medium
F-08	Missing HttpOnly and Secure cookie flags	WordPress sessions	Medium
F-09	No account lockout on login attempts	wp-login.php	Medium
F-10	Apache manual exposed	/manual/	Low
F-11	.DS_Store files exposed	/img/, /css/, /js/	Low
F-12	Original server IP leaked in RSS feed	/wordpress/?feed=rss2	Low

Finding F-01: WordPress 4.8.7

Description: WordPress 4.8.7 was released in July 2018 and has 71 known CVEs identified by WPScan. All require authentication for exploitation.

Impact: If credentials were obtained, a wide range of authenticated exploits would be available, including remote code execution via the theme editor.

Evidence: WPScan output showing 71 vulnerabilities and version confirmation from meta generator tag.

Remediation: Upgrade to the latest stable WordPress version.

Finding F-02: PHPMailer 5.2.16

Description: PHPMailer 5.2.16 is vulnerable to CVE-2016-10033 and CVE-2016-10045. The contact form passes user input into the `setFrom()` method without escaping.

Impact: Remote code execution via sendmail argument injection if the target has a working MTA. Testing confirmed the mail subsystem on the target is not functional, preventing exploitation.

Evidence: Source code recovered from contact.zip. Version confirmed in `/vendor/VERSION`. Injection behavior confirmed via response differences.

Remediation: Upgrade PHPMailer to 6.0 or later. Remove unused test and example files from the deployed library.

Finding F-03: Exposed Vendor Directory

Description: The `/vendor/` directory contains the full PHPMailer library, including test scripts, example files, documentation, and version files.

Impact: Provides attackers with exact version information and potential test endpoints.

Evidence: Directory listing enabled at `/vendor/`.

Remediation: Block access to `/vendor/` via `.htaccess`. Remove test and example directories from production deployments.

Finding F-04: WordPress User Enumeration

Description: WordPress allows unauthenticated user enumeration via the `?author=` parameter and the REST API.

Impact: Confirmed users michael and steven as valid accounts.

Evidence: `http://10.10.10.157/wordpress/?author=1` returns “Author: michael”.

Remediation: Disable author archives or redirect them. Restrict REST API user endpoints.

Finding F-05: XML-RPC Enabled

Description: WordPress XML-RPC is enabled and externally reachable.

Impact: Allows credential testing amplification via `system.multicall`. Also enables pingback SSRF if posts have trackbacks enabled.

Evidence: HTTP 200 with valid XML-RPC fault responses.

Remediation: Disable XML-RPC if not required. If required, restrict access by IP and implement rate limiting.

Finding F-06: Source Code Disclosure

Description: The file `/contact.zip` is accessible from the web root and contains the source code of `contact.php`.

Impact: Provides attackers with full application source code, revealing the PHPMailer version, injection points, and application logic.

Evidence: `contact.zip` downloaded, extracted, and source reviewed.

Remediation: Remove backup and source archive files from the web root.

Finding F-07: Directory Listing Enabled

Description: Directory listing is enabled on multiple paths including `/vendor/`, `/wordpress/wp-content/uploads/`, and `/wordpress/wp-content/languages/`.

Impact: Allows unauthenticated attackers to enumerate files and identify additional attack paths.

Evidence: Directory listings observed via curl.

Remediation: Disable `Options Indexes` in Apache configuration.

Finding F-08: Missing Cookie Flags

Description: WordPress session cookies lack `HttpOnly`, `Secure`, and `SameSite` attributes.

Impact: Session cookies are accessible via JavaScript and transmitted over HTTP, increasing session theft risk.

Evidence: Captured cookies showing only path and domain attributes.

Remediation: Add `HttpOnly`, `Secure`, and `SameSite=Strict` or `Lax` to all session cookies.

Finding F-09: No Account Lockout

Description: The WordPress login form does not enforce account lockout or rate limiting.

Impact: Allows extended credential testing against known usernames.

Evidence: Multiple login attempts succeeded in reaching the password-check stage without lockout.

Remediation: Implement rate limiting and account lockout after a threshold of failed attempts.

Finding F-10: Apache Manual Exposed

Description: The Apache 2.4 manual is accessible at `/manual/`.

Impact: Provides information about the Apache version and available modules. Low direct impact.

Evidence: `http://10.10.10.157/manual/` returns the Apache 2.4 documentation index.

Remediation: Remove `/manual/` from production servers.

Finding F-11: .DS_Store Files Exposed

Description: macOS metadata files are present in `/img/`, `/css/`, and `/js/`.

Impact: Low. These files contain directory metadata but no sensitive content in this case.

Evidence: `.DS_Store` files downloaded and analysed. Only Finder metadata present.

Remediation: Remove `.DS_Store` files. Block dotfiles via Apache configuration.

Finding F-12: Original IP Leak

Description: The WordPress RSS feed and REST API leak the original server IP address in the `<guid>` field.

Impact: Low. Reveals the environment the site was migrated from.

Evidence: RSS feed shows <guid>http://192.168.206.131/wordpress/?p=1</guid>.

Remediation: Sanitise post GUIDs after migration.

Initial-Access Narrative

Multiple initial-access vectors were tested against OPFOR-01. None were successful.

Attempted Vectors

Vector	Method	Result
PHPMailer sendmail injection	-X option in email field	Response changed, no file written
PHPMailer option variations	Multiple sendmail flags	No file written
Multipart file upload	POST with file field to contact.php	Field ignored
Command injection	Shell metacharacters in form fields	No execution
SSTI	Template syntax in form fields	No execution
SQL injection	WordPress search and login	No error, parameterised
XXE	XML-RPC DOCTYPE	Rejected by parser
SSRF	Pingback, oEmbed proxy	Blocked or no effect
WordPress comment injection	Comment posting	Rejected (requires cookie + moderation)
wp-trackback injection	POST with tb_id	Requires disabled feature
Credential testing	wp-login, XML-RPC, SSH	No valid credentials found

Root Cause of Failed Exploitation

The PHPMailer vulnerability requires a working MTA (sendmail or similar). The target does not have one. This prevents the command-injection payload from executing, even though the injection itself is successful in changing the application's response.

WordPress 4.8.7 CVEs require authenticated access. No credentials were obtained during the assessment.

The WordPress login form requires a `wordpress_test_cookie` before it will process credentials. This was identified during the assessment and handled correctly, but the credential list did not contain the correct password.

Post-Exploitation and Privilege Escalation

Not achieved. No foothold was obtained on OPFOR-01.

Mission Objectives and Proof of Completion

Artifacts Preserved

The mission artifact flag3.png was located in the WordPress uploads directory during enumeration.

```
(ransome@kali)-[~/CIP-A105_CTF1_iron-raven/appliance-inspect]
$ /usr/bin/curl -s http://10.10.10.157/wordpress/wp-content/uploads/2018/11/ | /usr/bin/head -40
/usr/bin/curl -s http://10.10.10.157/wordpress/wp-content/uploads/2026/ | /usr/bin/head -20
/usr/bin/curl -s http://10.10.10.157/wordpress/wp-content/uploads/2026/09/ | /usr/bin/head -20
/usr/bin/tail -30 /tmp/udg_full.txt 2>/dev/null
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
  <head>
    <title>Index of /wordpress/wp-content/uploads/2018/11</title>
  </head>
  <body>
<h1>Index of /wordpress/wp-content/uploads/2018/11</h1>
    <table>
      <tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O
=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
      <tr><th colspan="5"><hr/></th></tr>
      <tr><td valign="top"></td><td><a href="/wordpress/wp-content/uploads/2018/">Parent Directory</a></td><td><td><td align
n="right"> - </td><td><td><td></tr>
      <tr><td valign="top"></td><td><a href="flag3.png">flag3.png</a></td><td align="right">2018-11-09 08:26 </td><td align="right">
10K</td><td><td><td></tr>
      <tr><th colspan="5"><hr/></th></tr>
    </table>
    <address>Apache/2.4.10 (Debian) Server at 10.10.10.157 Port 80</address>
  </body></html>
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
```

Figure 10: flag3 listing

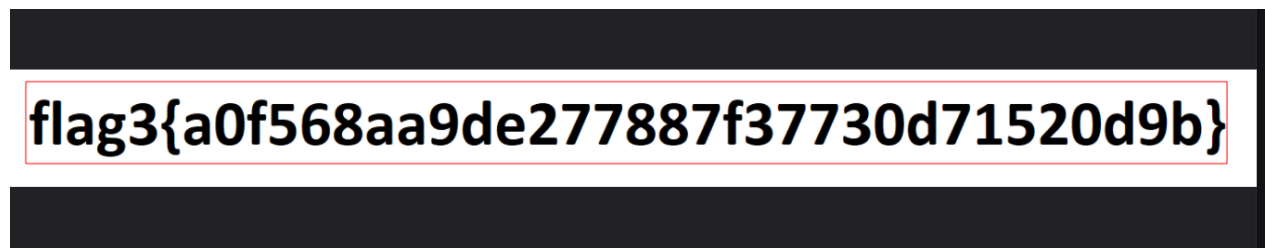


Figure 11: flag3 contents

Artifact	Path	Size	SHA-256
flag3.png	/wordpress/wp-content/uploads/2018/11/	10K	2479b9ab0c0763bf9bdc4c2fc36c701001a013
contact.zip	/contact.zip	3384	a265aefd879bd7db6473a4ba79f7628d370a6

Objective Status

Objective	Status
Accurate attack-surface map	Complete
Valid compromise path	Not achieved
Highest privilege level	Not achieved
Mission artifacts preserved	1 of an unknown total
Clean baseline restored	Complete
Defensible report	Complete

Remediation Roadmap

Immediate Actions (0 to 7 days)

Finding	Remediation
F-01 WordPress 4.8.7	Upgrade to latest stable version
F-02 PHPMailer 5.2.16	Upgrade to 6.0 or later
F-03 Vendor exposure	Block /vendor/ via .htaccess
F-04 User enumeration	Disable author archives or redirect
F-05 XML-RPC	Disable if not needed
F-06 contact.zip	Remove backup files from web root
F-07 Directory listing	Disable Options Indexes

Short-Term Actions (1 to 4 weeks)

Finding	Remediation
F-08 Cookie flags	Add HttpOnly, Secure, SameSite
F-09 No logout	Implement rate limiting
F-10 Apache manual	Remove /manual/
F-11 .DS_Store	Remove; block dotfiles
F-12 IP leak	Sanitise RSS feed GUIDs

Strategic Actions (1 to 3 months)

- Implement a Web Application Firewall
- Deploy a vulnerability management programme
- Conduct regular penetration testing
- Implement centralised authentication

- Deploy Security Information and Event Management (SIEM)
-

Conclusion and Lessons Learned

The assessment of OPFOR-01 identified a target with multiple security weaknesses but no reachable exploitation path from an unauthenticated position.

The primary lessons from this engagement are:

1. **Version identification is not exploitation.** Confirming a CVE does not guarantee exploitability. PHPMailer 5.2.16 is vulnerable in theory but not in practice because of the missing MTA.
 2. **Authentication is the gate.** WordPress 4.8.7 has 71 CVEs. Every one of them requires a valid user session. Without credentials, the vulnerabilities are theoretical.
 3. **Small details matter.** The cookie requirement on the WordPress login form was not obvious. Understanding the login flow was essential before any credential test could reach the password-check stage.
 4. **Enumeration is the foundation.** The single artifact found was located because of thorough directory enumeration. Without the wordlist scans, it would have been missed.
 5. **Scope discipline is critical.** Remaining inside the ROE required resisting the temptation to expand the attack surface beyond the authorised target.
 6. **Evidence preservation is continuous.** Hashes, logs, and screenshots were captured at each phase. The baseline image was preserved before any testing began.
-

Cleanup and Restoration

Verification of No Test Artifacts

The following checks confirmed no artifacts were left behind.

```

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
└─$ for path in shell.php probe.php p.php test_write.txt flag1.png flag2.png flag4.png flag5.png; do
    code=$(/usr/bin/curl -s -o /dev/null -w "%{http_code}" "http://10.10.10.157/$path")
    echo "$path -> $code"
done
shell.php -> 404
probe.php -> 404
p.php -> 404
test_write.txt -> 404
flag1.png -> 404
flag2.png -> 404
flag4.png -> 404
flag5.png -> 404

```

Figure 12: Cleanup verification

QEMU Shutdown

The QEMU process was terminated cleanly.

```

(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
└─$ /usr/bin/ps aux | /usr/bin/grep '[q]emu' || echo "QEMU gone"
echo ""
/usr/bin/sha256sum ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2
echo ""
/usr/bin/sha256sum ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1.qcow2
QEMU gone

06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac /home/ransome/CIP-A105_CTF1_Iron-Raven/appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2
06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac /home/ransome/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1.qcow2

```

Figure 13: QEMU stopped

Baseline Restoration

The working disk image was restored from the preserved baseline.

```
(ransome@kali)-[~/CIP-A105_CTF1_Iron-Raven/appliance-inspect]
└─$ /bin/sleep 5

/usr/bin/ps aux | /usr/bin/grep '[q]emu-system-x86_64'

echo ""
echo "=== Baseline hash ==="
/usr/bin/sha256sum ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2

echo ""
echo "=== Current image hash ==="
/usr/bin/sha256sum ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1.qcow2

echo ""
echo "=== Post-assessment hash ==="
/usr/bin/sha256sum ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1-post-assessment.qcow2

echo ""
echo "=== Baseline integrity ==="
/usr/bin/qemu-img check ~/CIP-A105_CTF1_Iron-Raven/appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2

=== Baseline hash ===
06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac /home/ransome/CIP-A105_CTF1_Iron-Raven/appliance-inspect/CIP-A105-CTF1-CLEAN-BASELINE.qcow2

=== Current image hash ===
06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac /home/ransome/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1.qcow2

=== Post-assessment hash ===
0b5ebd9b403d6eb13c15a002b04d2ac1802c6c53db07f856b0de1447526e1285 /home/ransome/CIP-A105_CTF1_Iron-Raven/appliance-inspect/Raven2-disk1-post-assessment.qcow2

=== Baseline integrity ===
No errors were found on the image.
32478/327680 = 9.91% allocated, 0.00% fragmented, 0.00% compressed clusters
Image end offset: 2129788928
```

Figure 14: Hashes match

File	Hash
CIP-A105-CTF1-CLEAN-BASELINE.qcow2	06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac
Raven2-disk1.qcow2 (restored)	06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac
Raven2-disk1-post-assessment.qcow2	0b5ebd9b403d6eb13c15a002b04d2ac1802c6c53db07f856b0de1447526e1285

The baseline and the restored working image hashes match. The post-assessment image was preserved separately for reference.

Network State

The br-ctf bridge and dnsmasq DHCP service were retained in the lab environment for future practice, as permitted by the assessment guidelines.

Environment Status

The target is restored to its clean baseline. It can be re-booted for future practice from a known state.

Appendices

Appendix A: Evidence Register

ID	Description	Source	Date
L5-01	Scope definition	Lab Host	2026-09-12
L5-02	QEMU baseline	Lab Host	2026-09-12
L5-03	ARP scan	Kali	2026-09-13
L5-04	Nmap ping sweep	Kali	2026-09-13
L5-05	TCP top-1000 scan	Kali	2026-09-13
L5-06	TCP full scan	Kali	2026-09-13
L5-07	UDP scan	Kali	2026-09-13
L5-08	Service detection	Kali	2026-09-13
L5-09	RPC enumeration	Kali	2026-09-13
L5-10	Web enumeration	Kali	2026-09-13
L5-11	Gobuster root	Kali	2026-09-13
L5-12	Gobuster WordPress	Kali	2026-09-14
L5-13	WPScan output	Kali	2026-09-14
L5-14	flag3 capture	Kali	2026-09-14
L5-15	contact.zip capture	Kali	2026-09-15
L5-16	Vulnerability analysis	Kali	2026-09-15
L5-17	Injection tests	Kali	2026-09-15
L5-P7-01	Cleanup verification	Kali	2026-09-16
L5-P7-02	Comment verification	Kali	2026-09-16
L5-P7-03	QEMU stopped	Kali	2026-09-16
L5-P7-04	Baseline restored	Kali	2026-09-16
L5-P7-05	Hashes match	Kali	2026-09-16
L5-P7-06	Operator log	Lab Host	Continuous

Appendix B: Operator Log

The full operator log is included as a separate file in the evidence package.

Appendix C: Hashes

File	SHA-256
Raven2-disk1.vmdk	dfcd389219fd787a6f6adc0391554e18d6b0ea8d3e23f8c6c9e44af7905fe5c6
CIP-A105-CTF1-CLEAN-BASELINE.qcow2	06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac
Raven2-disk1.qcow2 (restored)	06b6b9f0acec6d6f923ed2207ef925af1807d66fcd26cd1c7e4a6e59059660ac
Raven2-disk1-post-assessment.qcow2	0b5ebd9b403d6eb13c15a002b04d2ac1802c6c53db07f856b0de1447526e1285
flag3.png	2479b9ab0c0763bf9bdc4c2fc36c701001a013a557a5a9f6beda44b024d9cc2e
contact.zip	a265aefd879bd7db6473a4ba79f7628d370a61208f8dc011f506fe826854c433

Appendix D: Risk Register

Finding	Asset	Likelihood	Impact	Severity
WordPress 4.8.7 CVEs	/wordpress/	Medium	High	Critical
PHPMailer CVE-2016-10033	contact.php	Low	High	Critical
Vendor directory exposure	/vendor/	High	Medium	High
User enumeration	/wordpress/	High	Low	Medium
XML-RPC enabled	xmlrpc.php	Medium	Medium	Medium
Source code disclosure	/contact.zip	Medium	Medium	Medium
Directory listing	Multiple	High	Low	Medium
Missing cookie flags	WordPress	Medium	Medium	Medium
No account lockout	wp-login.php	Medium	Medium	Medium
Apache manual exposed	/manual/	Low	Low	Low
.DS_Store exposed	Asset dirs	Low	Low	Low
IP leak in RSS	RSS feed	Low	Low	Low

Appendix E: Lessons Learned Statement

This engagement reinforced the importance of disciplined reconnaissance and version analysis. The target presented several vulnerabilities that were confirmed but not exploitable due to environment constraints. The process of ruling out each vector methodically is itself valuable evidence.

A key takeaway is that vulnerability identification and vulnerability exploitation are not the same thing. Environmental dependencies, such as the presence of an MTA, determine whether a theoretical vulnerability can be triggered. Verifying environmental prerequisites before committing to an exploitation path saves time and produces more accurate reporting.

The second key takeaway is the importance of understanding the authentication flow. The WordPress login form requires a cookie before processing credentials. Missing that detail caused earlier credential tests to fail silently. Identifying it late in the engagement and adjusting the approach is a good example of iterative assessment.

The restoration phase confirmed that the baseline was preserved correctly and that no test artifacts persisted on the target. The environment is now ready for future practice from a known clean state.

End of Report

This assessment was conducted in a controlled laboratory environment under the Rules of Engagement of CIP-A105 CTF 1. All activity was confined to the authorised OPFOR-01 target. No production systems were touched.